WEB APPLICATION PENETRATION TEST — VULNERABILITY REPORT

Broken Function Level Authorization — Sub-admin to Admin Privilege Escalation

Finding NVP-005 · **High**

Product: PHPGurukul News Portal Project in PHP and MySQL — V4.1

Assessment target: http://localhost/newsportal/newsportal/

Technology: Apache 2.4.58 · PHP 8.2.12 · MariaDB 10.4.32 (DB user: root)

Assessment date: 2026-10-31

Classification: CONFIDENTIAL — authorised lab assessment (review draft)

Document Control

Finding ID	NVP-005
Vulnerability	Broken Function Level Authorization — Sub-admin to Admin Privilege Escalation
Severity	**High**
CVSS 4.0	8.3 `CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N`
CWE	CWE-862 (Missing Authorization); CWE-285 (Improper Authorization)
OWASP	A01:2021 Broken Access Control
CVE verification	No matching publicly assigned CVE was identified for this specific finding and product/version during the research performed.
Status	CONFIRMED (manually validated & re-verified)

1. Executive Summary

Sub-admin management is admin-only in the UI, but the server enforces only "is a session present" — not the role. A low-privileged sub-admin can directly open the admin-only pages and create, edit, or delete administrator/sub-admin accounts.

2. Affected Target

Affected URL	http://localhost/newsportal/newsportal/admin/add-subadmins.php, /admin/manage-subadmins.php, /admin/edit-subadmin.php
Affected parameter	n/a (forced browsing)
Affected role	Sub-admin (userType=0)
Authentication	Any authenticated sub-admin session

3. Technical Description

Every admin page guards with if(strlen($_SESSION["login"])==0). The userType value is consulted only in leftsidebar.php to show/hide the "Sub-admins" menu. There is no server-side role check on add-subadmins.php, manage-subadmins.php or edit-subadmin.php, so a sub-admin who forcibly browses to these URLs gains administrator-only functionality (and can create a new admin-capable account or delete sub-admins).

4. Root Cause Analysis

```
admin/add-subadmins.php:5 (and siblings): if(strlen($_SESSION['login'])==0)
{header('location:index.php');}
// guards presence of a session only.
```

```
admin/includes/leftsidebar.php:13: <?php if($_SESSION['utype']=='1'):?>  // role used ONLY for
menu rendering, not access control.
```

5. Preconditions

A sub-admin account (provided: subadmin/Test@123). The UI hides the menu, but the pages are reachable by direct URL.

6. Proof of Concept — Step-by-Step Reproduction

1. Log in as subadmin/Test@123. The dashboard sidebar shows NO "Sub-admins" menu (correctly hidden for userType=0).
2. Directly request /admin/manage-subadmins.php → HTTP 200, the full sub-admin list renders (not redirected to login).
3. Directly request /admin/add-subadmins.php → HTTP 200, the "Add Subadmin" form renders; POSTing it creates a new account.
4. The server performed no role check — a sub-admin exercised admin-only functionality.

7. HTTP Request Evidence

```
GET /newsportal/newsportal/admin/manage-subadmins.php HTTP/1.1
Host: localhost
Cookie: PHPSESSID=<sub-admin session>
```

8. HTTP Response Evidence

```
HTTP/1.1 200 OK
...
<h4 class="page-title">Manage Sub-admins</h4>  <!-- full list rendered for a sub-admin -->
```

9. Proof of Concept — Visual Evidence

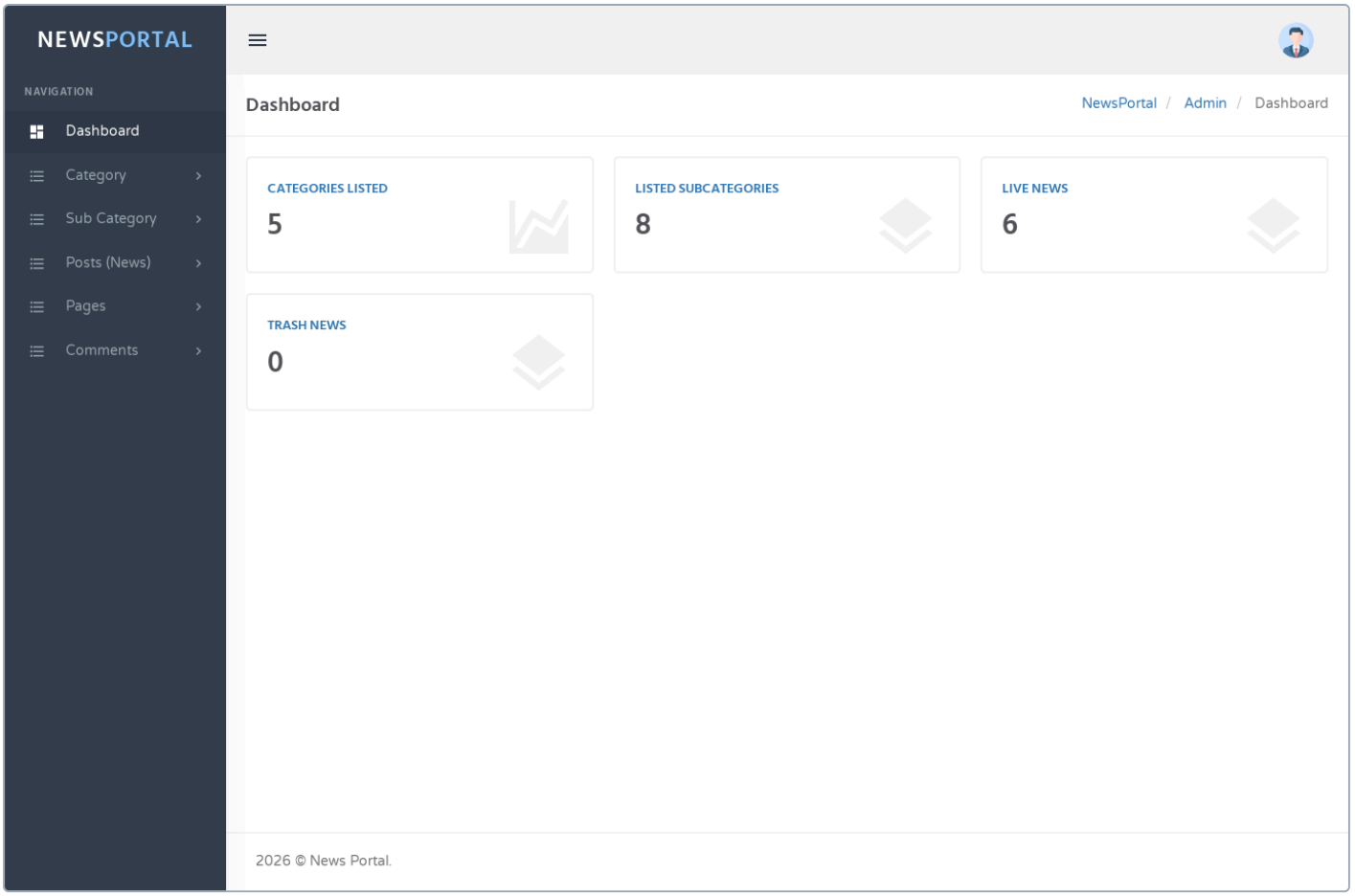


Figure 1 — Sub-admin dashboard: no "Sub-admins" menu (UI correctly hides it).

> What this proves: Establishes the sub-admin role and that the function is intended to be admin-only.

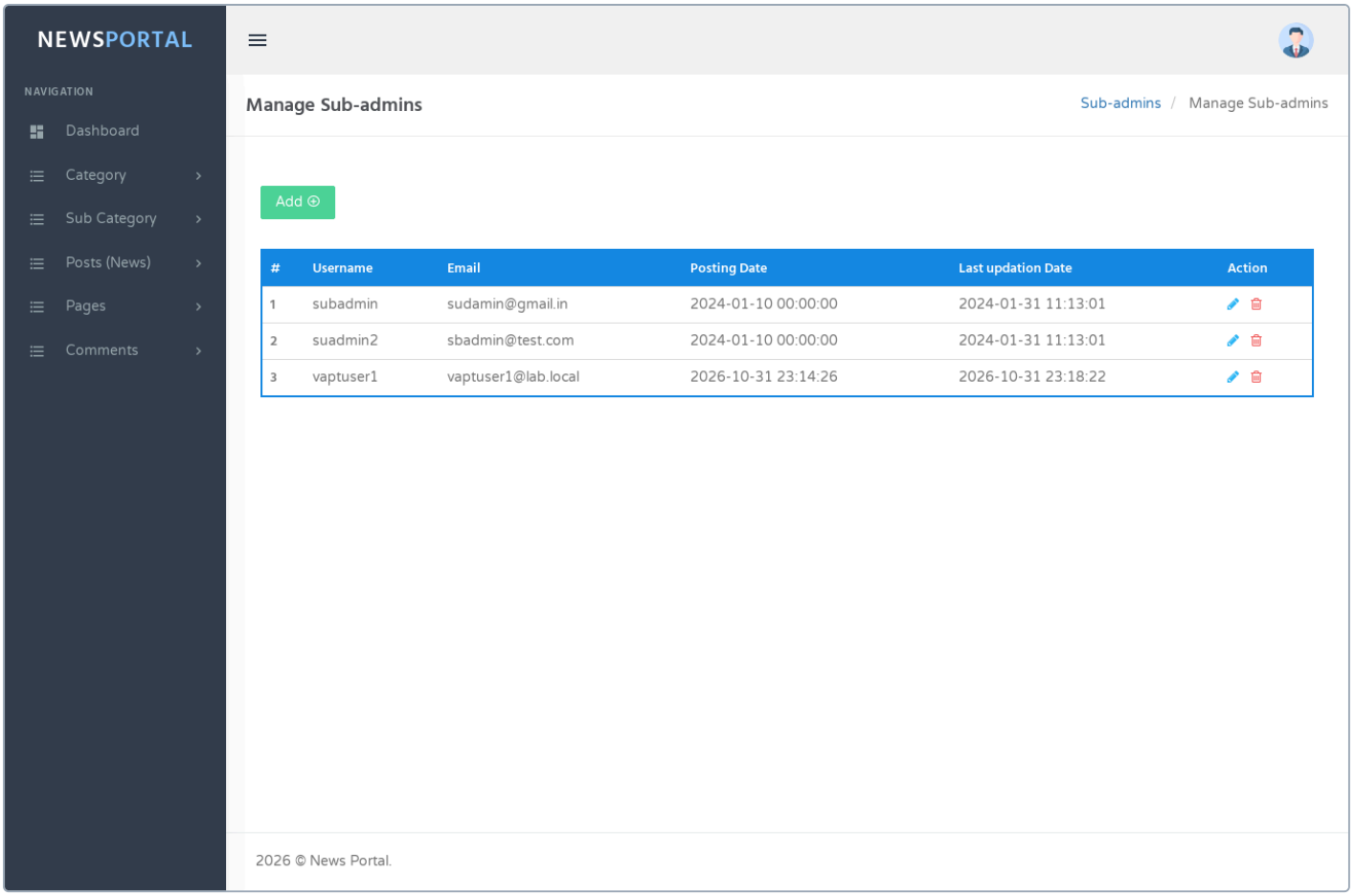


Figure 2 — Sub-admin opens admin-only Manage Sub-admins by direct URL.

> What this proves: Server returns the admin-only page to a sub-admin — missing server-side authorization.

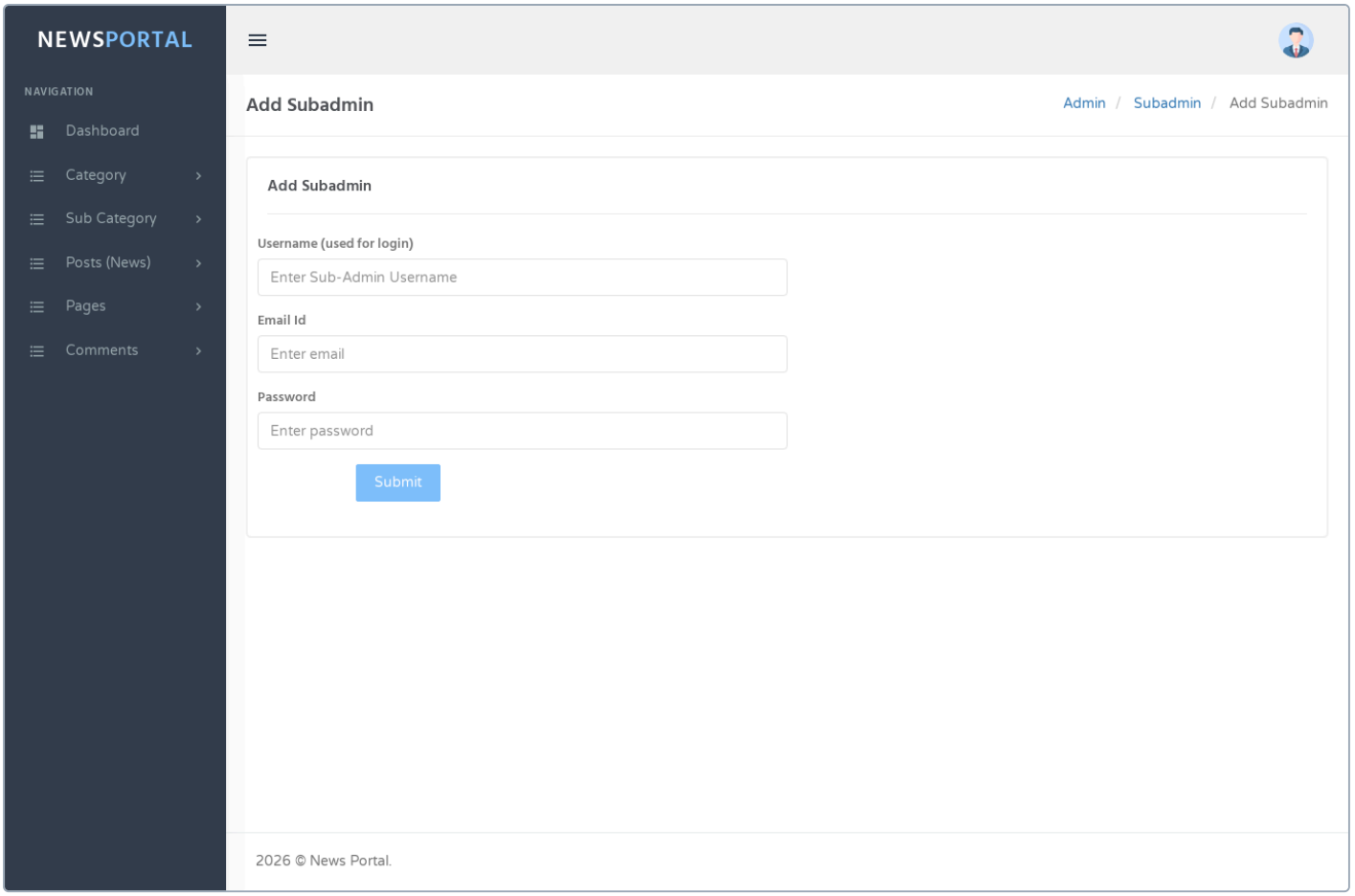


Figure 3 — Sub-admin opens the admin-only Add Sub-admin form.

> What this proves: The sub-admin can create accounts, completing the vertical privilege escalation.

10. Actual Security Impact

A low-privileged sub-admin escalates to administrator-equivalent control over accounts: create new accounts, delete other sub-admins, and modify account records — undermining the role separation the product advertises.

Exploitation complexity	Low — authenticated sub-admin simply visits the URLs.
Realistic attack scenario	A compromised or malicious sub-admin creates a new account/removes others, achieving durable admin-level control.

11. Remediation Recommendations

Enforce server-side role checks on every admin-only endpoint (e.g. require $_SESSION["utype"]==="1" at the top of add/manage/edit-subadmin). Hiding a menu is not access control. Centralise authorization in a shared guard.

Secure code example

```
// top of every admin-only page:
if ($_SESSION['utype'] !== '1') { http_response_code(403); exit('Forbidden'); }
```

12. Retesting Procedure

Repeat the direct-URL access with a sub-admin session; a fixed system returns 403/redirect and does not render the admin-only pages.

13. References

- CWE-862
- CWE-285
- OWASP WSTG-ATHZ-02
- OWASP A01:2021

14. Conclusion

Confirmed vertical privilege escalation via missing server-side authorization. Verified live with a sub-admin session.